
EMBEDDED HACKING

Reverse Engineering the Raspberry Pi Pico 2

OPERATION IRON GATE - Requirements & Grading Criteria

ARM Cortex-M33 • GDB • Ghidra

September 27, 2026

For educational and defensive security research only

OPERATION IRON GATE

REQUIREMENTS & GRADING CRITERIA

TARGET: NorthPharma logistics annex access gate
ARTIFACT: ACT-II.bin / ACT-II.uf2 (compromised)
CREW: FROSTLINE OPERATIVE: NIGHTINGALE

Project Overview

NorthPharma runs the cold chain that keeps a vaccine lot viable. Each annex is protected by a Pico 2 Access Gate and Vault Control node. A sabotage crew called **FROSTLINE** planted an implant called **WHITEOUT** in the gate image at the annex: a replayable grant, a forgeable grant, a tamperable SRAM verdict, and a fail-open timeout. Operative **NIGHTINGALE** recovered the compromised image as `ACT-II.bin`.

Students are the reverse-engineering reserve. They reverse engineer `ACT-II.bin` with Ghidra, find and patch all four defects, capture the state-tamper behavior live in GDB, export a corrected image, flash it to a real Pico 2, and prove the corrected behavior on the breadboard. The machine check is `scripts/verify_ctf.py`.

The challenge is a standalone capstone exercise and contains no answer, constant, address, bug, or patch belonging to any other course assignment.

Learning Objectives

- Decode an ARM Cortex-M33 vector and boot table and identify the reset handler and initial stack pointer.
- Map a stripped firmware image into modules by tracing calls from `main` and the monitor loop.
- Locate four corrupted bytes: an anti-replay branch, a tag-compare branch, an authenticated-state branch, and a fail-mode branch.
- Analyze condition codes, signed and unsigned compares, and branch inversion.
- Explain why authentication is not freshness and why authorization is not a boolean.
- Demonstrate the SRAM verdict attack with GDB and show that a keyed state tag catches it.
- Distinguish fail-secure from fail-open and defend designed egress.

Students must use only the course concepts: ARM registers, stack behavior, USB-CDC and UART consoles, GDB, Ghidra static analysis and binary patching, vector tables, reset startup, XIP, Thumb addressing, condition-code analysis, stateful security, and the Argon2id plus XChaCha20-Poly1305 authenticated envelope.

Deliverables Checklist

#	Deliverable	Format	Criterion
1	Ghidra project screenshot	PNG/JPG	Task 1
2	Vector table and boot table	Inside <code>ACT-II-Answers.md</code>	Task 1

#	Deliverable	Format	Criterion
3	<code>main</code> and monitor-loop table	Inside <code>ACT-II-Answers.md</code>	Task 1
4	Module map	Inside <code>ACT-II-Answers.md</code>	Task 1
5	Replay evidence and patch	Inside <code>ACT-II-Answers.md</code>	Task 2
6	Forge evidence and patch	Inside <code>ACT-II-Answers.md</code>	Task 3
7	State evidence, GDB proof, and patch	Inside <code>ACT-II-Answers.md</code>	Task 4
8	Fail-open evidence and patch	Inside <code>ACT-II-Answers.md</code>	Task 5
9	<code>ACT-II_fixed.bin</code>	BIN file	Task 6
10	<code>ACT-II_fixed.uf2</code>	UF2 file	Task 6
11	Hardware proof and reflection	Inside <code>ACT-II-Answers.md</code>	Task 6

Required Tools and Equipment

Tool	Purpose
Raspberry Pi Pico 2	Isolated target node
Debug Probe (OpenOCD)	SWD connection for GDB inspection
<code>arm-none-eabi-gdb</code>	Runtime breakpoints and the SRAM verdict attack
Ghidra	Static analysis and binary patching
Python 3 with <code>uf2conv.py</code>	UF2 conversion and artifact checks
DHT11, 1602 I2C LCD, RYL998, IR receiver, SG90 servo, 3 LEDs, REX button	Breadboard hardware proof
<code>ACT-II.bin</code> and <code>ACT-II.uf2</code>	Supplied compromised artifacts

Console settings: **USB-CDC virtual COM port, 115200 baud, 8 data bits, no parity, 1 stop bit**. Radio UART settings: **UART1, 115200, network ID 18**.

Artifact Identity

The instructor-issued artifact hashes are:

```

ACT-II.bin      da216cff3f569983dcf7d5e14d192c23d491ea8126abee8d4c153c58f8d5a282
ACT-II.uf2      ad146617c91d96445df0ebbad4c9e282c2cdc011de985a343323d3df107856ec
ACT-II_fixed.bin 3deba303f5daa5b48a6fda2c583cff76916ea7012a7b2bbb8f9ea4b71372d304
ACT-II_fixed.uf2 d8789dd83098b421ea669015873bb499ccb39c2571ecc54f51b30f6e7b2bf7fe

```

The verifier checks the `ACT-II.bin` and `ACT-II.uf2` hashes specifically, asserts the four fixed bytes in `ACT-II_fixed.bin`, and requires that only those four offsets differ between the two `.bin` images.

Grading Rubric - Detailed Breakdown

Task 1: Setup and Initial Analysis (10 points)

Criterion	Points	Full credit	Partial credit	No credit
[DOCUMENT] Ghidra project created with the correct name and settings	2	Project <code>IronGate_Investigation</code> , raw binary import	One item off	Not set up
[DOCUMENT] Processor configured as ARM Cortex 32 little endian default	2	Screenshot shows the correct processor	Wrong language	Missing
[DOCUMENT] Base address set to 0x10000000	2	Base <code>0x10000000</code>	Wrong base	Missing
[DOCUMENT] Vector table, initial stack pointer, and reset handler identified	2	Base <code>0x10000000</code> , initial SP <code>0x20082000</code> , reset handler <code>0x1000015D</code>	One missing	Not found
[DOCUMENT] main and the monitor loop (monitor_step) addresses identified	1	<code>main 0x10000234</code> , <code>monitor_step 0x100069D4</code>	One correct	Neither
[DOCUMENT] Module map identifies the keypad, auth, servo deadbolt, LEDs, DHT11 interlock, LCD access log, REX button, and sealed LoRa anchors	1	At least one correct anchor per module	Partial	Missing

Task 2: Bug #1 Replay (20 points)

Criterion	Points	Full credit	Partial credit	No credit
[DOCUMENT] Located the anti-replay branch at 0x10007F43	5	Address and function identified	Approximate	Not found
[DOCUMENT] Documented bcc.n versus bcs.n and the seq > last_seq rule	5	Correct branch semantics and strict-greater rule	Partial	Wrong
[DOCUMENT & PATCH] Patched 0xD2 to 0xD3 so the anti-replay window is restored	7	Byte <code>0xD2</code> changed to <code>0xD3</code>	Wrong byte	Not patched
[DOCUMENT] Explained that a captured GRANTED frame then fails to reopen the door	3	Freshness tracked by a strictly monotonic sequence	Vague	Missing

Task 3: Bug #2 Forge (20 points)

Criterion	Points	Full credit	Partial credit	No credit
[DOCUMENT] Located the tag-difference branch at 0x1000811D	5	Address and function identified	Approximate	Not found
[DOCUMENT] Documented the constant-time tag compare and the branch condition	5	Zero difference means accept	Partial	Wrong

Criterion	Points	Full credit	Partial credit	No credit
[DOCUMENT & PATCH] Patched 0xD1 to 0xD0 so forged grants fail authentication	7	Byte 0xD1 changed to 0xD0	Wrong byte	Not patched
[DOCUMENT] Explained why a non-zero Poly1305 tag difference must be rejected	3	A non-zero difference means forged or corrupt	Vague	Missing

Task 4: Bug #3 State (20 points)

Criterion	Points	Full credit	Partial credit	No credit
[DOCUMENT] Located the authenticated-state branch at 0x10006797	5	Address and inlined release path identified	Approximate	Not found
[DOCUMENT] Documented the auth_state_ok gate and the branch condition	5	Deny when the state tag does not match	Partial	Wrong
[DOCUMENT & PATCH] Patched 0xD1 to 0xD0 so the authenticated-state check is restored	7	Byte 0xD1 changed to 0xD0	Wrong byte	Not patched
[DOCUMENT] Demonstrated with GDB that g_auth.granted = 1 without recomputing the tag no longer opens the door	3	Command sequence and the correct observed rejection	Partial	Missing

Task 5: Bug #4 Fail-Open (20 points)

Criterion	Points	Full credit	Partial credit	No credit
[DOCUMENT] Located the fail-mode branch at 0x10006BCB	5	Address and inlined fail-mode path identified	Approximate	Not found
[DOCUMENT] Documented fail-secure versus fail-open on an authorization timeout	5	Correct policy and branch semantics	Partial	Wrong
[DOCUMENT & PATCH] Patched 0xB9 to 0xB1 so a timeout leaves the bolt locked	7	Byte 0xB9 changed to 0xB1	Wrong byte	Not patched
[DOCUMENT] Explained that an authorization timeout must fail secure	3	The bolt stays locked when no grant arrives	Vague	Missing

Task 6: Export and Verify (10 points)

Criterion	Points	Full credit	Partial credit	No credit
[PATCH] Exported ACT-II_fixed.bin from Ghidra	2	Valid patched binary	Corrupt	Not submitted
[PATCH] Converted to ACT-II_fixed.uf2 with the correct base and family	2	--base 0x10000000 --family 0xe48bff59	Wrong flags	Not submitted

Criterion	Points	Full credit	Partial credit	No credit
[DOCUMENT] scripts/verify_ctf.py passes and hardware proves the correct behavior	3	Verifier passes and the hardware proof is shown	Partial proof	No proof
[DOCUMENT] Reflection maps each of the four defects to a real-world access-control failure	3	Specific mapping for all four	Partial	Missing

Common Pitfalls

Pitfall	Consequence	Avoidance
Reading the replay branch backwards	Captured grants still reopen the door	Accept only on <code>last_seq < seq (bcc.n, 0xD3)</code>
Confusing <code>beq</code> and <code>bne</code> at <code>0x811D</code>	Forged grants still authenticate	Accept only on zero tag difference (<code>beq.n, 0xD0</code>)
Missing that the release path is inlined	Cannot find the state gate	Look inside <code>monitor_rx_tick</code> at <code>0x10006797</code>
Treating the SRAM verdict as a crypto problem	Wrong layer fixed	The state tag, not the cipher, catches the tamper
Missing that the fail-mode path is inlined	Cannot find the timeout branch	Look inside <code>monitor_step</code> at <code>0x10006BCB</code>
Patching it to fail open by habit	Timeout unlocks the bolt	Fail secure is the correct ingress default
Forgetting UF2 conversion	Raw binary will not flash	Use <code>uf2conv.py</code> with family <code>0xe48bff59</code>
Fabricating the GDB session	Verification fails	Show the command sequence and the real rejection

How To Breadboard

Device	Pin on device	Pico 2 GPIO	Notes
DHT11 data	DATA	GP4	10 kOhm pull-up to 3.3 V if the module needs it
1602 LCD	SDA	GP2	I2C1, backpack address <code>0x27</code>
1602 LCD	SCL	GP3	I2C1, 100 kHz
1602 LCD	VCC / GND	VBUS 5 V / GND	The backpack needs 5 V, not 3.3 V
RYLR998	RX	GP8 (Pico TX)	UART1, 115200, network ID 18
RYLR998	TX	GP9 (Pico RX)	UART1
IR receiver	OUT	GP5	VS1838B, internal pull-up enabled
Servo	signal	GP14	PWM 50 Hz; 1000 uF bulk cap across servo 5 V and GND

Device	Pin on device	Pico 2 GPIO	Notes
Red LED	anode	GP16	220 to 330 ohm to GND
Yellow LED	anode	GP17	220 to 330 ohm to GND
Green LED	anode	GP18	220 to 330 ohm to GND
REX button	leg 1	GP15	Internal pull-up; leg 2 to GND, never to 3.3 V
Onboard LED	built in	GP25	Heartbeat
Debug Probe	SWCLK / SWDIO / GND	debug header	For GDB only

Use 3.3 V logic on every GPIO. The only 5 V connection is the LCD backpack supply. Keep the 1000 uF capacitor on the servo rail.

Memory Map Reference

Region	Address	Purpose
Bootrom	0x00000000	Immutable boot code
Flash/XIP	0x10000000	Vector table, code, rodata, data image
SRAM	0x20000000	Stack and writable state
Authorization record <code>g_auth</code>	0x20013334	Verdict, pending flag, <code>seq</code> , <code>last_seq</code>
Authorization key <code>g_auth_key</code>	0x20013350	State-tag key material
Derived field key <code>g_key</code>	0x20013378	32-byte Argon2id field key
Key-ready flag <code>g_key_ready</code>	0x20013963	True once the field key is installed

The VA of any file offset is the file offset plus `0x10000000`.

Deadline & Submission

- Create a folder containing the Ghidra screenshot, `ACT-II_fixed.bin`, and `ACT-II_fixed.uf2`.
- Write all written answers in `ACT-II-Answers.md` inside that folder.
- Include the output of `python scripts/verify_ctf.py`.
- ZIP the folder as `lastname-firstname-ACT-II.zip`.
- Submit the ZIP before the posted deadline; late submissions lose 10 percent per day.

Grade Scale

Grade	Percentage	Points
A+	97-100%	97-100

Grade	Percentage	Points
A	93-96%	93-96
A-	90-92%	90-92
B+	87-89%	87-89
B	84-86%	84-86
B-	80-83%	80-83
C	70-79%	70-79
F	0-69%	0-69

Academic Integrity

Use only the supplied Pico 2 and firmware. Do not connect the exercise to an operational access-control system, a pharmaceutical network, a public network, a military system, or a third-party device. This is a controlled, isolated educational exercise. All analysis and patches must be your own work; sharing binaries, addresses, keys, passphrases, or answers is a violation of the academic integrity policy.

Reference Material

Topic	Reference
ARM Cortex-M33 registers and stack	Course block 1
USB-CDC and UART console capture	Course block 2
Vector tables, reset startup, and XIP	Course block 3
Ghidra static analysis and binary patching	Course block 4
Condition-code and branch analysis	Course block 5
Anti-replay windows and state integrity	Course block 6
Argon2id and XChaCha20-Poly1305 authenticated envelope	Course block 7
Fail-secure policy and designed egress	Course block 8